

ISYS90090 · CYBERSECURITY MANAGEMENT

Week 4

Risk, Policy, Strategy & SETA

From asset protection to organisational capability.

Atif Ahmad · University of Melbourne

“If you think technology can solve your security problems, then you don't understand the problems and you don't understand the technology.”

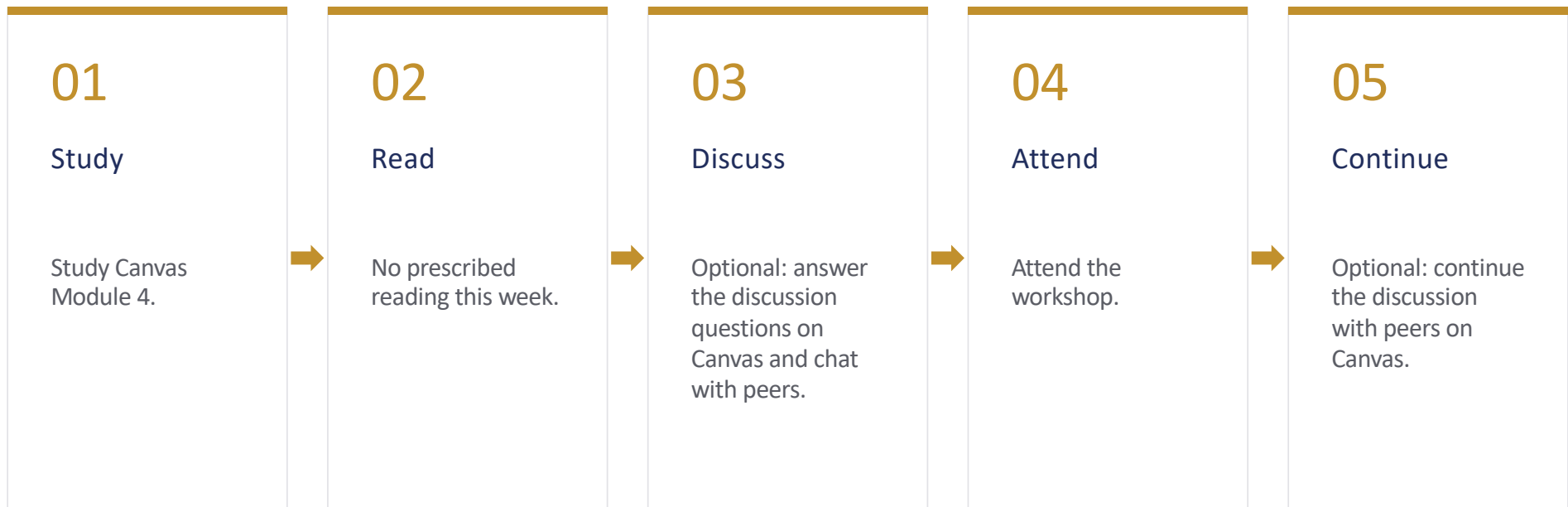
BRUCE SCHNEIER

“Security is a process, not a product.”

BRUCE SCHNEIER

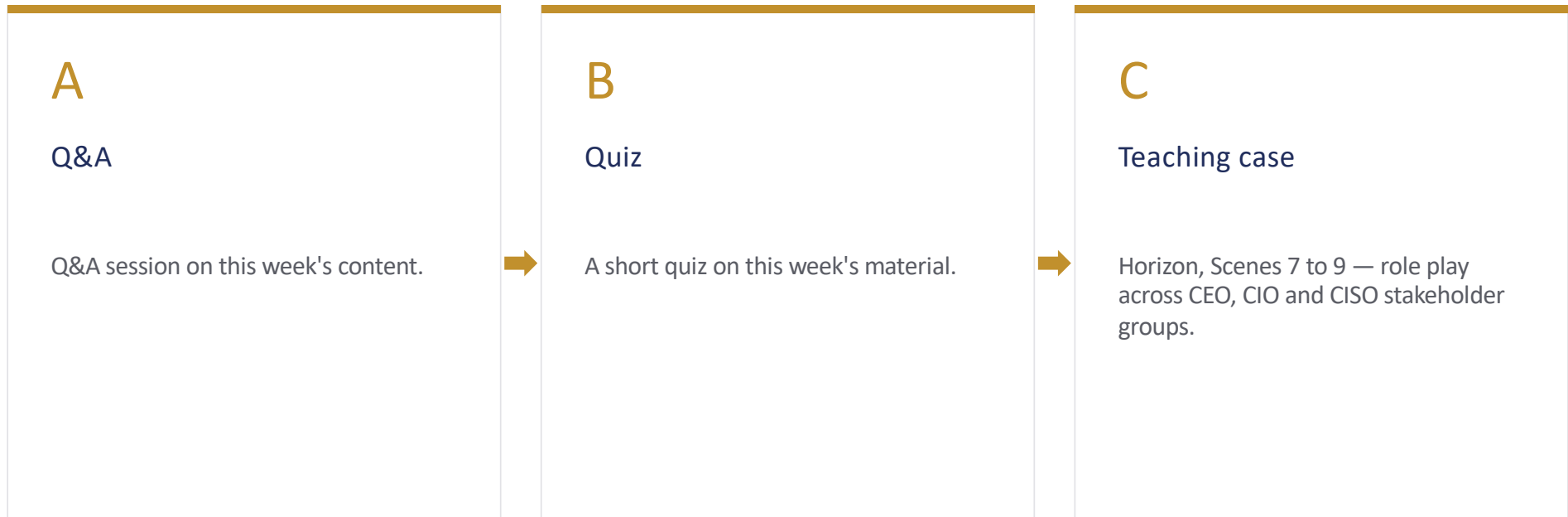
THIS WEEK

This week in cybersecurity management



THIS WEEK'S WORKSHOP

Workshop structure



INTENDED LEARNING OBJECTIVES

By the end of this week, you will be able to

01

Risk process

Define the high-level phases in the information security risk management process.

02

Policy success factors

Explore the critical success factors that let security policy protect information resources without disrupting business productivity.

03

SETA

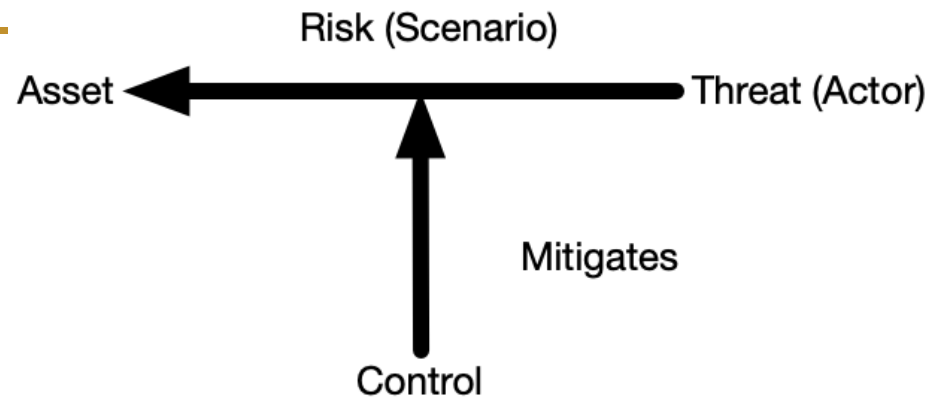
Explore strategies for improving SETA in organisations.

SECTION 01

Risk management

From assets and threats to a disciplined risk process.

The triplet model



A security problem needs two ingredients: an asset worth protecting, and a threat capable of reducing its value. Risk is a scenario — a specific threat actor exploiting a specific vulnerability in a specific asset. Security cannot eliminate risk; leadership finds the balance between investment and residual risk it is willing to accept.

The full portfolio of risk scenarios across an organisation's assets and threats is its risk exposure.

ASSET

A valuable resource that requires protection — logical or physical.

THREAT

A source of danger capable of reducing the asset's value.

CONTROL

Technological, formal or informal measures that reduce likelihood and/or impact.

Cybersecurity risk management



What security risks can you identify?

Fiona, the regional security manager for LegalCo, is staring out her large floor-to-ceiling window overlooking the park. She notices Jim sitting on a bench, frantically typing on his laptop — he must be working on the pricing strategy for tomorrow's tender proposal. A young woman stops a few metres away and appears interested in his screen. Fiona freezes: she recognises her as an employee of a competitor across the street. She grabs her handbag and heads for the park.

What's the asset?

What's the threat?

What's the vulnerability?

What's the impact?

So what's the risk (scenario)?

A Question...

- Consider two experienced CISOs. Both implement a program of security controls — one uses a risk assessment to inform decision-making, the other uses a compliance checklist from an established international standard.
- Which practice is better? Why?

SECTION 02

Policy, strategy and SETA

Turning risk understanding into direction and behaviour.

Cybersecurity policy management

“A policy is a plan or course of action that conveys instructions from an organisation's senior management to those who make decisions, take actions, and perform other duties.”

WHITMAN AND MATTORD, 2012, P.177

Policy

Strategic-level guidance from senior management.

Practices / procedures

Operational-level guidance that implements policy day to day.

Standards (some texts)

An intermediate layer built on policy, more detailed than practices.

Why policy, and how do you know it's working?

Q1

Why policy?

Why do we need a policy in the first place?

Q2

Success factors

What are the critical success factors for policy implementation?

Q3

Measuring it

How can we tell if the policy is working?

Cybersecurity strategy

Strategy prescribes a future course of security action — using formal, informal and technological controls at a tactical and operational level — to reduce risk exposure to confidentiality, integrity and availability.

Prescriptive

A decision about a future course of action.

Multi-faceted

Trades off preserving C, I, A against resource expenditure, risk and effectiveness.

Top-down

Culminates in a plan enacted by security management, coherent enterprise-wide.

Security education, training and awareness

The role of SETA

- An informal but powerful control on employee behaviour
- Reinforces policy and strategy by creating routinised behaviour
- Sets expectations of employees around security

Why SETA programs tend to fail

- Encourages behaviour inconsistent with the organisation's culture
- Driven by compliance with rules and regulations, not genuine buy-in
- Competes with many other training programs for employee attention
- Not fully integrated and reinforced by policy, risk, strategy and culture

What are the key challenges for the CISO?

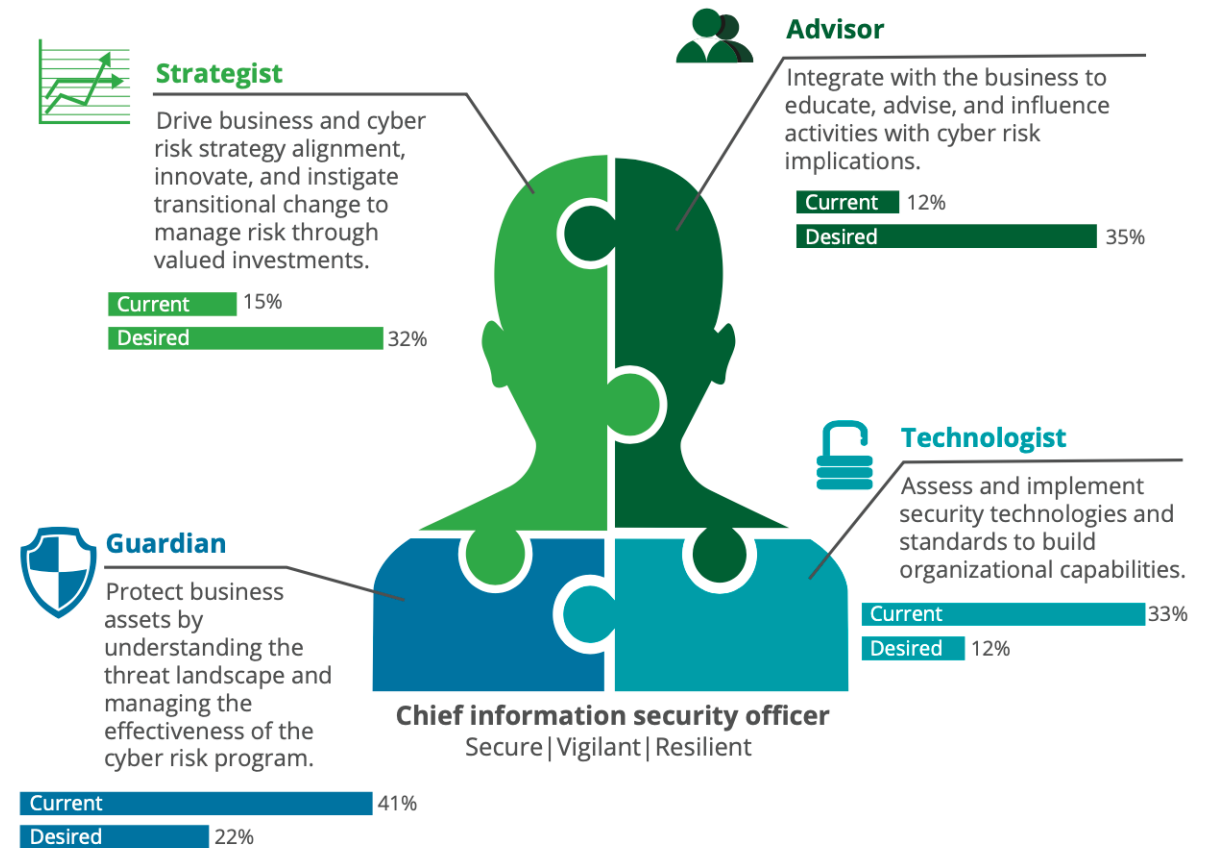
Challenge 1 — Bridging the business/cyber disconnect

- Narrow perspective
- Communication limitations
- Talent shortage

Challenge 2 — Articulating a business value proposition

- False sense of security
- Competing agendas

Four faces of the CISO



Source: Research from Deloitte's CISO Transition Labs.

Graphic: Deloitte University Press | DUPress.com

Q&A

Questions and discussion